



Federal Office
for Information Security

Technical Guideline TR-03183-H

Cyber Resilience Requirements for Manufacturers and Products

Conformity based on full quality assurance
(Module H)

Version: 1.1.0
Date: 30/05/2026

Document History

Table 1: Document History

Date	Header	Description
30/05/2026	Federal Office for Information Security (BSI)	Publication Version 1.1.0

Federal Office for Information Security
P.O. Box 20 03 63
53133 Bonn
E-Mail: TR03183@bsi.bund.de
Internet: <https://bsi.bund.de/dok/TR-03183-en>
© Federal Office for Information Security 2023 - 2025

Table of Contents

1	Introduction.....	4
2	Scope.....	5
3	Normative references.....	8
4	Terms and definitions.....	9
5	CRA-specific requirements related to ISO/IEC 27001.....	10
5.1	General.....	10
5.2	Applicability of cybersecurity controls for products.....	10
5.3	CRA 4.2 Understanding the needs and expectations of interested parties.....	10
5.4	CRA 4.3 Determining the scope of the information security management system.....	11
5.5	CRA 5.2 Policy.....	11
5.6	CRA 6.1.2 Information security risk assessment.....	11
5.7	CRA 6.1.3 Information security risk treatment.....	12
5.8	CRA 6.3 Planning of changes.....	13
5.9	CRA 7.4 Communication.....	13
5.10	CRA 7.5.1 Documented information - General.....	13
5.11	CRA 8.1 Operational planning and control.....	14
6	CRA-specific guidance related to ISO/IEC 27002.....	15
6.1	General.....	15
6.2	CRA 5.7 Threat intelligence.....	15
6.3	CRA 5.8 Information security in project management.....	15
6.4	CRA 8.8 Management of technical vulnerabilities.....	15
6.5	CRA 8.25 Secure development life cycle.....	16
6.6	CRA 8.29 Security testing in development and acceptance.....	17
6.7	CRA 8.32 Change management.....	17
A	Essential cybersecurity requirements.....	18
A.1	Essential cybersecurity requirements Part I.....	18
A.2	Essential cybersecurity requirements Part II.....	20
B	Module H in Context of CRA (informative).....	23
B.1	Requirements for Module H.....	23
B.2	Benefits of Module H for manufacturers.....	24
B.3	Drawbacks of Module H.....	25
B.4	Special considerations for conformity assessment under the CRA.....	25
C	Concept for implementation of Module H on ISO/IEC 27001 (informative).....	27
C.1	Module H based on ISO 9001.....	27
C.2	Module H based on ISO/IEC 27001.....	28
C.3	Concept TR-03183-H.....	28
C.4	Conclusion.....	30
D	Overview of relevant quality system aspects (informative).....	32
E	Application of TR-03183-1 (informative).....	33
F	References.....	34

1 Introduction

This Technical Guideline describes a way to demonstrate conformity with the essential cybersecurity requirements of the EU Regulation 2024/2847 "Cyber Resilience Act" (CRA) [1] based on full quality assurance (Module H, Annex VIII CRA) using an ISO/IEC 27001[2]-compliant ISMS. This is achieved by refining and extending the requirements of the ISO/IEC 27001 to include the design, development or production as well as the vulnerability handling of products with digital elements (PwDE) and part thereof subject to the CRA.

Module H is a conformity assessment procedure based on certification of the manufacturer's processes as an alternative to module B+C, which is based on the examination of the product itself by a notified body (NB). For additional information on the differences between module H and module B+C as well as their use cases, see Appendix B.

This document is NOT a new management system standard independent of ISO/IEC 27001, but rather

- a. specifies CRA-specific requirements that are composed of refinements of and additions to requirements in ISO/IEC 27001 based on the essential cybersecurity requirements of the Cyber Resilience Act as set out in Appendix A.
- b. specifies CRA-specific guidance that supports additions to and/or modifications of ISO/IEC 27002 (see Clause 6).

Existing information security management systems can be extended to cover design, development, production and vulnerability handling processes for PwDE in scope.

2 Scope

The scope of this Technical Guideline is the application of the requirements of ISO/IEC 27001 and additional requirements for products under the scope of the CRA.

This Technical Guideline addresses organisations developing or manufacturing PwDE or having PwDE designed, developed or manufactured, and marketing them under their name or trademark, i.e. the manufacturer (CRA Article 3 Point 13). This applies even if the product is not directly placed on the European market by the manufacturer itself.

As shown in Figure 1, the scope of the ISMS includes the business services for placing a PwDE on the market as well as the business services for providing remote data processing solutions (RDPS) as part of the PwDE.

Note: The specific definition of RDPS belonging to a PwDE relies on additional guidance by the European Commission. In the meantime, this guideline will assume that RDPS entails at least software designed, developed and operated by or on behalf of the manufacturer, whose absence would prevent the product with digital elements from performing one of its functions. (Article 3 Point 2 CRA)

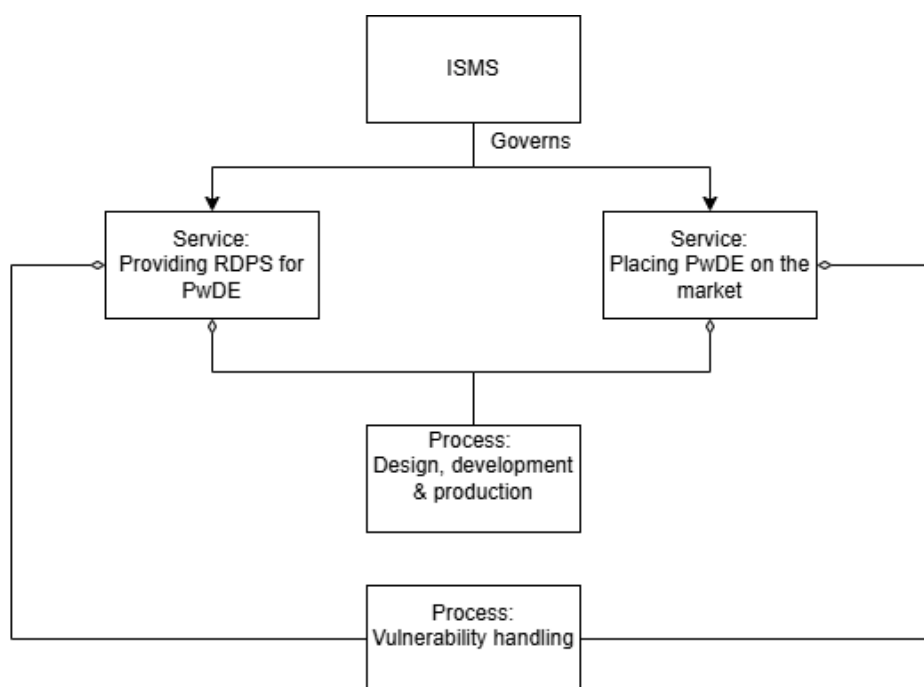


Figure 1. Scope of ISMS for PwDE

Note: Generally, the RDPS is a part of the PwDE and therefore subject to the same requirements under the CRA. For the sake of clarity, this Technical Guideline differentiates between the two since the RDPS stays under the control of the manufacturer and the PwDE placed on the market is operated by a third-party user. Preferably both parts follow the same processes.

Both of the above-mentioned services include design, development or production as well as vulnerability handling processes in relation to their respective output. These two processes form the quality system ensuring appropriate cybersecurity as a quality goal during the lifecycle of the PwDE as shown in Figure 2.

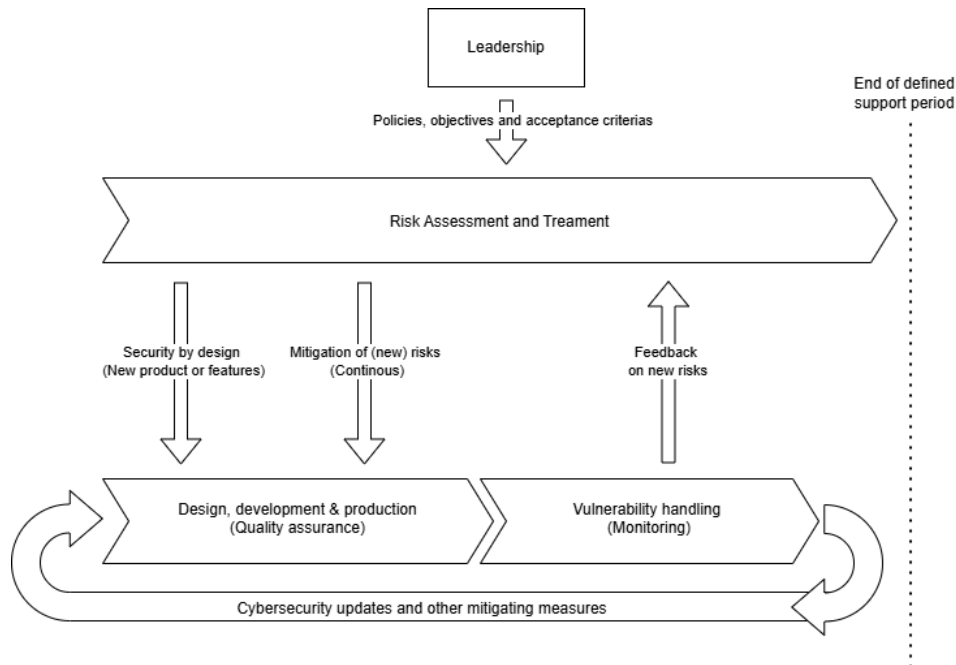


Figure 2. Lifecycle Module H

Requirements of ISO/IEC 27001 apply to central aspects like management responsibility including the definition of cybersecurity policies, objectives and risk acceptance criteria as well as a continuous risk assessment and treatment until the end of the defined support period, thereby establishing the basis of the design, development and production process as well as the vulnerability handling process of the PwDE in scope.

The design, development and production process is the central quality assurance mechanism ensuring that the PwDE fulfils the cybersecurity requirements established by the risk assessment. This includes

- planning and approving of changes,
- verification and testing of requirements during product provision and release,
- managing of external suppliers,
- handling non-conformity

as well as other relevant quality assurance aspects.

The vulnerability handling process as well as the continuous risk assessment are responsible for monitoring and maintaining the cybersecurity of the PwDE during its defined support period and might result in updates or other mitigating measures for the PwDE already placed on the market. These measures are regarded as changes to the PwDE and are subject to the design, development and production process.

To ensure quality, additional requirements of ISO 9001 [3] in the context of module H will be applied. The rationale for applying both management system standards is described in Appendix C as well as an overview of the quality system aspects of TR-03183-H in comparison to ISO 9001 as set out in Appendix D.

Additional requirements will be applied for the design, development and production as well as the vulnerability handling processes for PwDEs in scope based on the essential cybersecurity requirements set out in Appendix A of this Technical Guideline with a view to providing an appropriate level of cybersecurity with regard to affected third-parties.

A single ISMS may cover several types of PwDE and product lines, provided that all relevant lifecycle processes are included in scope.

3 Normative references

ISO/IEC 27000, Information technology – Security techniques – Information security management systems – Overview and vocabulary [4]

ISO/IEC 27001, Information security, cybersecurity and privacy protection – Information security management systems – Requirements [2]

ISO/IEC 27002, Information security, cybersecurity and privacy protection – Information security controls [5]

ISO 9001, Quality management systems – Requirements [3]

TR-03183-1: Cyber Resilience Requirements for Manufacturers and Products [6]

4 Terms and definitions

For the purposes of this Technical Guideline, the terms and definitions given in ISO/IEC 27000 as well as the definitions in Article 3 of the CRA apply.

Additional definitions as used in this Technical Guideline are given below:

Affected third-party

User, society and other third-parties potentially adversely affected by a cybersecurity risk of the PwDE in scope.

Conformance specification

Conformance specifications are harmonised European standards (hEN) or common specifications cited for presumption of conformity in their respective scope. These specifications provide structured control sets and assessment criteria for auditable requirements, which are deemed to be fit for use and purpose.

Design, development and production process

Processes of the manufacturer resulting in placing a PwDE on the market or performing modifications to the PwDE including all relevant activities from initial concept to final product as well as quality assurance processes to ensure that the PwDE fulfils Annex I Part I CRA.

PwDE in scope

PwDE, type of PwDE or multiple types of PwDE developed or manufactured by the manufacturer or designed, developed or manufactured on behalf of the manufacturer, and marketed under the name or trademark of the manufacturer, which is subject to the processes set out in this Technical Guideline to demonstrate conformity.

Vulnerability handling process

The process of identifying, evaluating, treating and disclosing vulnerabilities in a PwDE during its defined support period in accordance with Annex I Part II CRA. Treatment includes mitigation or elimination of the vulnerability through appropriate measures such as patches, updates or workarounds. Any changes to the PwDE in scope including RDPS as well as involved processes and documentation resulting from this process are subject to the design, development and production process.

5 CRA-specific requirements related to ISO/IEC 27001

5.1 General

All requirements from ISO/IEC 27001, Clauses 4 to 10, that do not appear below shall apply unchanged.

5.2 Applicability of cybersecurity controls for products

This Technical Guideline refers to conformance specifications for specific product types and use cases. These specifications refine the essential cybersecurity requirements set out in CRA Annex I or part thereof and follow certain assumptions given in this Technical Guideline.

Conformance specifications are harmonised European standards (hEN) or common specifications cited for presumption of conformity in their respective scope. These specifications provide structured control sets and assessment criteria for auditable requirements, which are deemed to be fit for use and purpose.

Conformance specifications shall be used to interpret, implement and assess the essential cybersecurity requirements.

Deviation from a conformance specification shall only be possible in appropriately justified cases.

The justification shall take into account the cybersecurity risks based on the intended purpose and reasonably foreseeable use, as well as the conditions of use, of the product with digital elements, such as the operational environment or the assets to be protected as well as the length of time the product is expected to be in use.

In the absence of a conformance specification or deviation from a conformance specification, sector-specific standards and best practices should be applied.

The Technical Guideline BSI TR-03183-1 is not regarded as a conformance specification but can be used as guidance without a conformity claim following Appendix E.

5.3 CRA 4.2 Understanding the needs and expectations of interested parties

ISO/IEC 27001, 4.2 is refined as follows.

1. Interested parties that are relevant to the information security management system shall at least include the manufacturer and affected third-parties;
2. Relevant requirements of these interested parties include at least the requirement for the manufacturer's conformity with the CRA and the affected third-parties' expectations regarding an appropriate level of cybersecurity based on the risks of the PwDE in scope;

3. Requirements addressed through the information security management system include at least the requirement for the manufacturer's conformity with the CRA as well as expectations of the affected third-parties regarding an appropriate level of cybersecurity based on the risk of the PwDE in scope;

5.4 CRA 4.3 Determining the scope of the information security management system

ISO/IEC 27001, 4.3 is refined as follows.

The scope of the information security management system must include at least the PwDE in scope as well as the following services related to the PwDE in scope:

1. Placing a PwDE on the market consisting of:
 - a. The design, development and production process of the PwDE in scope
 - b. The vulnerability handling process of the PwDE in scope required to maintain the PwDE operated by a third-party user during its defined support period
2. Providing RDPS of the PwDE:
 - a. The design and development process resulting in providing an RDPS as part of the PwDE in scope
 - b. The vulnerability handling process of the RDPS as part of the PwDE required to maintain the RDPS operated by the manufacturer or on behalf of the manufacturer during its defined support period

Note: The processes in scope of this Technical Guideline can handle multiple types of PwDE. In this case the processes shall assure that each type of PwDE is subject to the appropriate conformance specification, if available.

5.5 CRA 5.2 Policy

ISO/IEC 27001, 5.2 b) is refined as follows.

1. information security objectives shall include at least
 - a. that the PwDE in scope ensures an appropriate level of cybersecurity based on the risks as set out in Annex I Part I CRA.
 - b. that the manufacturer fulfils the vulnerability handling requirements as set out in Annex I Part II CRA during the defined support period of PwDE in scope.

Note: The information security objectives are equivalent to the quality objectives when applying ISO 9001 requirements in the context of this Technical Guideline.

5.6 CRA 6.1.2 Information security risk assessment

ISO/IEC 27001, 6.1.2. is refined as follows.

The risk acceptance criteria as set out in 6.1.2. a) 1) shall include the following criteria:

1. Non-conformity with the CRA is not acceptable.
2. Risks to affected third-parties can only be accepted if an appropriate level of cybersecurity based on the intended purpose and reasonably foreseeable use of the PwDE in scope is ensured.

Assumption: This Technical Guideline assumes that a conformance specification defines, at least implicitly, appropriate acceptance criteria for risks of affected third-parties in their respective scope.

The identified risks as set out in 6.1.2. c) shall include at least:

1. the risks of a non-CRA-compliant PwDE
2. all relevant cybersecurity risks with impact on affected third-parties resulting from loss of confidentiality, integrity and availability of the PwDE's functionality or the data handled by the PwDE based on the intended purpose and reasonably foreseeable use, as well as the conditions of use, of the product with digital elements, such as the operational environment or the assets to be protected, taking into account the length of time the product is expected to be in use.

The risk owner as set out in 6.1.2. c) for non-conformity and risks with impact on affected third-parties is the manufacturer.

The analysis of the information security risks as set out in 6.1.2. d), shall take into account the impact and likelihood of an incident based on the intended purpose and reasonably foreseeable use of the PwDE, as well as the conditions of use, of the product with digital elements, such as the operational environment or the assets to be protected, taking into account the length of time the product is expected to be in use.

Assumption: This Technical Guideline assumes that a reproducible identification and analysis strategy for risks to affected third-parties or a list of risks/threats to be mitigated is set out in any conformance specification for Annex I Part I CRA.

5.7 CRA 6.1.3 Information security risk treatment

In addition to ISO/IEC 27001, 6.1.3, the following CRA-specific requirements apply:

6.1.3 a-1) In addition to 6.1.3. a) the information security risk treatment options shall include a secure development lifecycle (8.28) including information security in project management (5.8) and security testing in development and acceptance (8.29) as well as change management (8.32) as part of the design, development and production process ensuring an appropriate level of cybersecurity based on the risks assessed in 6.1.2 in order to fulfil the applicable requirements of A.1 in conjunction with applicable conformance specifications, if available.

6.1.3 a-2) In addition to 6.1.3. a) the information security risk treatment options shall include management of technical vulnerabilities (8.8) including threat intelligence (5.7) as part of the vulnerability handling process of the manufacturer in order to fulfil all requirements of A.2 in conjunction with applicable conformance specifications, if available.

6.1.3 c-1) In addition to 6.1.3. c) the information security risk treatment process shall compare the controls of the PwDE in scope implemented as part of the secure development lifecycle in 6.1.3 a-1) above with those in Annex A.1 and based on the risk verify that no necessary controls have been omitted.

6.1.3 d-1) The produced statement of applicability shall in relation to the PwDE in scope also include appropriate risk based justification for omitting any controls in Annex A.1 during the secure development lifecycle of the PwDE in scope based on the risk acceptance criteria defined in 6.1.2 a) above.

Assumption: This Technical Guideline assumes that a conformance specification for Annex I Part I CRA refines applicable essential cybersecurity requirements with specific controls and potentially excludes some essential cybersecurity requirements using a risk-based justification.

5.8 CRA 6.3 Planning of changes

ISO/IEC 27001, 6.3. is refined as follows.

Changes to the information security management system in relation to the PwDE in scope shall be carried out in a planned manner as specified in ISO 9001 6.3.

5.9 CRA 7.4 Communication

ISO/IEC 27001, 7.4. is refined as follows.

The determined need for external communication shall at least include communication with users of the PwDE in scope providing at least the necessary information set out in Annex II CRA.

The determined need for external communication shall take into account the capabilities and expectations of the user of the PwDE in scope.

Note: User information can be part of a control necessary to mitigate identified risks to an acceptable level. This is relevant as manufacturers cannot ensure appropriate competence of third-party users of the PwDE. The competency required for parts of the PwDE operated by the manufacturer or on behalf of the manufacturer, i.e. the RDPS, can be provided through internal communication.

Note: The manufacturer may take into account different user groups if different aspects of the PwDE are subject to different user groups, e.g. end-user, administrator or integrator.

5.10 CRA 7.5.1 Documented information - General

In addition to ISO/IEC 27001 7.5.1, the following CRA-specific requirements apply:

7.5.1-1) The manufacturer's information security management system shall include documented information according to ANNEX VII CRA for the PwDE in scope where applicable.

7.5.1-2) The manufacturer's information security management system shall include documented information according to ANNEX VIII 3.2 for the CRA.

7.5.1-3) Documented information as required by 7.5.1-1 and 7.5.1-2 shall be truthful, correct, current and sufficiently complete to monitor and evaluate the design, development and production process of the PwDE in scope as well as the vulnerability handling processes of the manufacturer to demonstrate conformity.

7.5.1-4) Documented information as required by 7.5.1-2 and 7.5.1-3 should be structured in a way to allow reuse and automation, e.g. by using a structured data format like OSCAL [7]

5.11 CRA 8.1 Operational planning and control

ISO/IEC 27001, 8.1. is refined as follows.

The criteria for the design, development and production process of the PwDE shall include that risk treatment options defined in 6.1.3 b-1) are implemented or otherwise realized as designed and appropriately and objectively verified based on the associated risk before placing a PwDE on the market.

Note: It is generally possible to outsource activities to capable third-parties, e.g. third-party conformity assessment bodies for verification. However, the manufacturer must ensure that the outsourced activities are subject to the same requirements as the internal processes and that the manufacturer has sufficient control over them to ensure conformity with this Technical Guideline.

The criteria for the vulnerability handling process of the manufacturer shall include that the controls as defined in 6.1.3 b-2) are implemented by the manufacturer as part of the vulnerability handling process during the defined support period of the PwDE in scope.

Assumption: This Technical Guideline assumes that any conformance specification of Annex I Part I CRA is either concise enough or gives additional guidance to verify that controls determined in 6.1.3 b-1) are properly implemented by the PwDE in scope. Furthermore, this Technical Guideline assumes that any conformance specification for Annex II CRA is either concise enough or gives additional guidance to verify that the controls determined in 6.1.3. b-2) are provided by the manufacturer as part of the vulnerability handling process.

In addition to ISO/IEC 27001 8.1, the following CRA-specific requirements apply.

8.1.1 The design, development and production process shall fulfil the requirements for design and development of products set out in ISO 9001 8.3

8.1.2 The design, development and production process shall fulfil the requirements for control of externally provided processes, products and services set out in ISO 9001 8.4

8.1.3 The design, development and production process shall fulfil the requirements for production set out in ISO 9001 8.5.

Note: ISO 9001 8.5.3 applies primarily to data of the consumer/user used by or under the control of the organisation, although tangible property might also be affected in case of an incident.

8.1.4 The design, development and production process shall fulfil the requirements for release of PwDEs set out in ISO 9001 8.6

Note: If not otherwise defined by a conformance specification, the manufacturer's arrangements to verify that the PwDE meets the requirements should include the elements set out in Annex VIII Part II Point 2) as well as Point 4) CRA.

8.1.5 The design, development and production process shall fulfil the requirements for control of non-conforming outputs set out in ISO 9001 8.7

6 CRA-specific guidance related to ISO/IEC 27002

6.1 General

All clauses, control objectives, controls, implementation guidance and other information from ISO/IEC 27002 that do not appear below apply unchanged.

6.2 CRA 5.7 Threat intelligence

Control 5.7 is modified as follows

Control

Information relating to information security threats **at least to the PwDE in scope** should be collected and analysed to produce threat intelligence.

Purpose

To provide awareness of the **PwDE in scope's** and organisation's threat environment so that the appropriate mitigation actions can be taken.

[...]

6.3 CRA 5.8 Information security in project management

Control 5.8 is modified as follows

Control

Information security should be integrated into project management **at least of the PwDE in scope**.

Purpose

To ensure information security risks related to projects and deliverables are effectively addressed in project management throughout the project life cycle. **This applies at least to the project life cycle of the PwDE in scope**

[...]

6.4 CRA 8.8 Management of technical vulnerabilities

Control 8.8 is modified as follows

Control

Information about technical vulnerabilities of information systems in use **as well as PwDEs in scope** should be obtained, the organisation's and **PwDE in scope's** exposure to such vulnerabilities should be evaluated and appropriate measures should be taken.

Purpose

To prevent exploitation of technical vulnerabilities.

Guidance

To identify, evaluate, communicate and take appropriate measures to address technical vulnerabilities, a conformance specification for Annex I Part II CRA should be applied for the management of technical vulnerabilities for the **PwDE in scope**.

[...]

6.5 CRA 8.25 Secure development life cycle

Control 8.25 is modified as follows

Control

Rules for the secure development of software, **hardware** and systems should be established and applied **at least for the design, development and production of PwDE in scope**

Purpose

To ensure information security is designed and implemented within the secure development life cycle of software, **hardware** and systems **at least for the design, development and production of PwDE in scope**

Guidance

Secure development is a requirement to build up a secure service, architecture, software, **hardware** and system **at least for the design, development and production of PwDE in scope**.

To achieve this, the following aspects should be considered:

[...]

c. security requirements in the specification and design phase including

1. if not already done in 6.1.2, a product-specific risk assessment based on the risk for affected third-parties assessed in CRA 6.1.2;
2. product-specific controls able to provide an appropriate level of cybersecurity based on the risks of the PwDE in scope (Annex I Part I 1 CRA) as well as to fulfil the applicable cybersecurity requirements of Annex I Part I 2 CRA using one or more appropriate conformance specifications for Annex I Part I.

d. security checkpoints in projects ensuring that

1. the PwDE in scope is not placed on the market without fulfilling the security requirements
2. changes to the PwDE in scope already placed on the market maintain the security requirements

e. system and security testing, such as regression testing, code scan and penetration tests able to verify that

1. the security requirements are fulfilled before placing the PwDE in scope on the market
2. the security requirements are upheld during the defined support period of the PwDE in scope

[...]

6.6 CRA 8.29 Security testing in development and acceptance

Control 8.29 is modified as follows

Control

Security testing processes should be defined and implemented in the development life cycle **at least for the design, development and production of PwDE in scope.**

Purpose

To validate if information security requirements are met when applications or code **as well as hardware** are deployed to the production environment, **distributed to the user or placed on the market.**

[...]

6.7 CRA 8.32 Change management

Control 8.32 is modified as follows

Control

Changes to information processing facilities and information systems **as well as the PwDE in scope** should be subject to change management procedures.

Purpose

To preserve information security when executing changes.

Guidance

Introduction of new systems and major changes to existing systems **as well as all changes to the PwDE in scope** should follow agreed rules and a formal process of documentation, specification, testing, quality control and managed implementation.

[...]

A Essential cybersecurity requirements

A.1 Essential cybersecurity requirements Part I

Table 1: Annex I Part I Requirement 1

ID	CRA Reference	Requirement
ER.0	Annex I Part I 1	Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.

On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall:

Table 2: Annex I Part I Requirement 2

ID	CRA Reference	Requirement
ER.1	Annex I Part I 2 Point a	be made available on the market without known exploitable vulnerabilities;
ER.2	Annex I Part I 2 Point b	be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements
ER.3a	Annex I Part I 2 Point b	including the possibility to reset the product to its original state;
ER.4	Annex I Part I 2 Point c	ensure that vulnerabilities can be addressed through security updates,
ER.4a	Annex I Part I 2 Point c	including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting,
ER.4b	Annex I Part I 2 Point c	with a clear and easy-to-use opt-out mechanism,
ER.4c	Annex I Part I 2 Point c	through the notification of available updates to users,
ER.4d	Annex I Part I 2 Point c	and the option to temporarily postpone them;

ID	CRA Reference	Requirement
ER.5	Annex I Part I 2 Point d	ensure protection from unauthorised access by appropriate control mechanisms,
ER.5a	Annex I Part I 2 Point d	including but not limited to authentication, identity or access management systems,
ER.5b	Annex I Part I 2 Point d	and report on possible unauthorised access;
ER.6	Annex I Part I 2 Point e	protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;
ER.7	Annex I Part I 2 Point f	protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;
ER.8	Annex I Part I 2 Point g	process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);
ER.9	Annex I Part I 2 Point h	protect the availability of essential and basic functions, also after an incident,
ER.9a	Annex I Part I 2 Point h	including through resilience and mitigation measures against denial-of-service attacks;
ER.10	Annex I Part I 2 Point i	minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;
ER.11	Annex I Part I 2 Point j	be designed, developed and produced to limit attack surfaces,

ID	CRA Reference	Requirement
ER.11a	Annex I Part I 2 Point j	including external interfaces;
ER.12	Annex I Part I 2 Point k	be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;
ER.13	Annex I Part I 2 Point l	provide security related information by recording and monitoring relevant internal activity,
ER.13a	Annex I Part I 2 Point l	including the access to or modification of data, services or functions,
ER.13b	Annex I Part I 2 Point l	with an opt-out mechanism for the user;
ER.14	Annex I Part I 2 Point m	provide the possibility for users to securely and easily remove on a permanent basis all data and settings.
ER.14a	Annex I Part I 2 Point m	and where such data can be transferred to other products or systems, ensure that this is done in a secure manner

A.2 Essential cybersecurity requirements Part II

Manufacturers of products with digital elements shall:

Table 3: Annex I Part II

ID	CRA Reference	Requirement
VH.1	Annex I Part II 1	identify and document vulnerabilities and components contained in products with digital elements,
VH.1a	Annex I Part II 1	including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;
VH.2	Annex I Part II 2	in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay,

ID	CRA Reference	Requirement
VH.2a	Annex I Part II 2	including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;
VH.3	Annex I Part II 3	apply effective and regular tests and reviews of the security of the product with digital elements;
VH.4	Annex I Part II 4	once a security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the security benefits, they may delay making public information regarding a fixed vulnerability until after users have been given the possibility to apply the relevant patch;
VH.5	Annex I Part II 5	put in place and enforce a policy on coordinated vulnerability disclosure;
VH.6	Annex I Part II 6	take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third-party components contained in that product,
VH.6a	Annex I Part II 4	including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements;
VH.7	Annex I Part II 7	provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and,
VH.7a	Annex I Part II 7	where applicable for security updates, in an automatic manner;

ID	CRA Reference	Requirement
VH.8a	Annex I Part II 8	unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.

B Module H in Context of CRA (informative)

Module H is one of the conformity assessment methods set out in the Decision No 768/2008/EC of the European Parliament [8] for EU's New Legislative Framework and applicable for usage under the CRA according to Article 32 CRA besides the internal control procedure (Module A), an EU-type examination with additional internal control (Module B+C) and where available and applicable, a European cybersecurity certification scheme pursuant to Article 27(9). Module H is a conformity assessment procedure based on full quality assurance, which means that the manufacturer must implement and maintain a comprehensive quality system that covers all aspects of the product's lifecycle, including design, development, production and vulnerability handling. An appropriate notified body (NB) audits the manufacturer's quality system to ensure that the PwDE meets the requirements of the CRA for the category of PwDE in scope and approves it if the requirements are met.

Module H as well as Module B+C are primarily intended to be used for Products with Digital Elements listed as important products of class I and II in Annex II CRA.

However, conformity for products in important class I can also be demonstrated with the internal control procedure in conjunction with hEN cited for presumption of conformity. This might be more cost-efficient as no third-party has to be involved.

Critical products should be assessed using an applicable Cyber Security Act (CSA) scheme granting presumption of conformity, as any other conformity assessment procedure used for critical products, i.e. Module H or Module B+C, might be rendered unsuitable for demonstrating conformity if an applicable scheme will be mandated following Article 8(1) .

B.1 Requirements for Module H

The requirements for Module H are set out in Annex VIII of the CRA and are based on an approved quality system for the design, development and final product inspection and testing of the products with digital elements concerned and for handling vulnerabilities, maintaining cybersecurity throughout the support period.

The system operated by the manufacturer shall ensure conformity of the products with digital elements with the essential cybersecurity requirements set out in Part I of Annex I and conformity of the vulnerability handling processes put in place by the manufacturer according to the requirements set out in Part II of Annex I. This can be simplified by leveraging harmonised European standards (hEN) giving presumption of conformity with the essential requirements of the CRA.

The quality system shall be approved by a notified body on the basis of an audit of the manufacturer's quality system and a review of documentation. The auditing team shall have at least one member experienced as an assessor in the relevant product field and product technology concerned, and shall have knowledge of the applicable requirements of Annex I Part I CRA. The audit shall include an assessment visit to the manufacturer's premises as well as a review of the technical documentation for one model of each category of products with digital elements containing at least the elements set out in Annex VII.

All the elements, requirements and provisions adopted by the manufacturer shall be documented in a systematic and orderly manner in the form of written policies, procedures and instructions. This quality system documentation shall permit a consistent interpretation of the quality programmes, plans, manuals and records including

- the technical design and development specifications to ensure that the essential cybersecurity requirements set out in Part I of Annex I will be met;
- the procedural specifications to ensure that the essential cybersecurity requirements set out in Part II of Annex I will be met;
- the design and development control, as well as design and development verification techniques and processes;
- the corresponding production, quality control and quality assurance techniques and processes;
- the examinations and tests that will be carried out before, during and after production, and the frequency with which they will be carried out;
- the quality records, such as inspection reports and test data, calibration data and qualification reports on the personnel concerned;
- the means of monitoring the achievement of the required design and product quality and the effective operation of the quality system.

The manufacturer is obliged to fulfil the obligations arising out of the quality system as approved and to maintain it so that it remains adequate and efficient. The manufacturer is responsible for informing the NB about planned changes to the quality system, upon which the NB must evaluate if the quality system still satisfies the requirements set out in Annex VIII Part IV CRA or whether a reassessment is necessary.

The NB shall carry out periodic audits to make sure that the manufacturer maintains and applies the certified quality system.

B.2 Benefits of Module H for manufacturers

The main benefit of Module H is that it allows manufacturers to demonstrate conformity with the essential cybersecurity requirements through a comprehensive quality system. This can be more flexible than other conformity assessment procedures, such as Module B+C, which requires an EU-type examination for every product, valid only until a substantial modification to the PwDE is made.

The certification for Module H relies on the quality system of the manufacturer and not the product itself, which means that the manufacturer can demonstrate conformity for a whole category of products with digital elements instead of having to demonstrate conformity for each individual product. This can be particularly beneficial for manufacturers that produce a large number of products with digital elements or that frequently update their products.

Furthermore, the use of Module H enables a continuous improvement process for the manufacturer, as the quality system is subject to regular audits and reviews by the NB as well as internal audits by the manufacturer. This can help manufacturers to identify and address potential issues with their products with digital elements and vulnerability handling processes before they become a problem, which can ultimately lead to better products and improved cybersecurity. The recertification cycle for quality systems generally includes a full multi-step audit every three years and annual surveillance audits [9].

Nevertheless, the flexibility of Module H has its limits as the manufacturer is generally not able to make changes to the quality system without notifying the NB beforehand and potentially undergoing a reassessment. This is generally the case for extending the scope of the quality system to cover additional categories of products with digital elements, but can also be the case for changes to the quality system aspects of design, development, production and vulnerability handling processes.

B.3 Drawbacks of Module H

The main drawback of Module H is that it has additional risks for manufacturers compared to other conformity assessment procedures. Since the certification relies on the quality system of the manufacturer and not the product itself, there is a risk that the manufacturer may not be able to demonstrate conformity for the complete production subject to the quality system if the certification for Module H is lost.

It is generally not possible to regain conformity for products which were produced without a valid certification, which can lead to significant financial losses for the manufacturer. This is also the case for products subject to Module B+C, but the risk is generally higher for Module H as the certification is not product-specific.

In addition, the internal processes and controls of the manufacturer must be robust enough to ensure that the products with digital elements produced under the quality system consistently meet the essential cybersecurity requirements of the CRA. This requires the manufacturer to have a strong commitment to cybersecurity and to invest in the necessary resources and expertise to maintain an effective quality system, which is subject to regular audits and reviews by the NB.

B.4 Special considerations for conformity assessment under the CRA

Although Module H and Module B+C are general concepts, the specific requirements for conformity assessment under the CRA are set out in the CRA itself, which means that there are specific considerations for the CRA-specific implementation.

As such, Module H is not just a quality system certification but also includes a review of the technical documentation for one model of each category of products with digital elements containing at least the elements set out in Annex VII CRA. This means that Module H cannot be achieved without a detailed sampling of a representative product with digital elements subject to the certified quality system. In comparison to Module B+C, this is equivalent to an EU-type examination for one representative product which generally relies on a documentation based design-type review.

The product-specific nature of Module H under the CRA is enhanced by the requirement that the auditing team shall have at least one member experienced as an assessor in the relevant product field and product technology concerned, and shall have knowledge of the applicable requirements. As such, Module H cannot be certified without a product-type-specific assessment.

On the other hand, Module B+C is not a static product-specific certification as it is always accompanied by regular audits of the vulnerability handling requirements of Annex I Part II CRA. This means that the certification is not only based on the static properties of the product with digital elements but also on the processes put in place by the manufacturer, which are subject to regular audits.

The vulnerability requirements of Annex I Part II also include regular testing and reevaluation of the product's cybersecurity measures. Following this, Module B+C also requires the central aspects of a quality system for cybersecurity, i.e. assessment, mitigation and monitoring of cybersecurity risks.

As such, the differences between Module H and Module B+C under the CRA are not as distinct as they might be in other regulatory contexts.

C Concept for implementation of Module H on ISO/IEC 27001 (informative)

The implementation of module H is generally based on management system standards such as ISO 9001 [3] for quality management systems (QMS) or the cybersecurity-specific ISO/IEC 27001 for information security management systems (ISMS). Both standards have important elements for the implementation of module H as described in Annex VII Part IV CRA.

C.1 Module H based on ISO 9001

A QMS based on ISO 9001 [3] is built upon the PDCA (Plan-Do-Check-Act) cycle, which describes a structured approach to define quality goals, implement processes to achieve those goals, monitor and evaluate the effectiveness of those processes, and make necessary adjustments if needed. The PDCA cycle is a continuous improvement process that helps organisations to identify and address potential issues with their products and processes.

Generally, a fully certified QMS based on ISO 9001 is able to meet the generic requirements for a quality system, including planning, implementation and verification of quality goals as well as leadership responsibility and supplier management. However, it is generally not necessary to include all the elements of ISO 9001 in the quality system for module H.

A QMS based on ISO 9001 is not specifically designed for cybersecurity and does not include all the necessary controls and processes to ensure conformity with the essential cybersecurity requirements of the CRA. As such, a QMS also does not automatically include an option during the operation phase to address emerging cybersecurity threats and vulnerabilities since a QMS does not anticipate the need to change a product after it has been developed and placed on the market, which is often the case in cybersecurity. The manufacturer might not be able to respond quickly enough to new threats and vulnerabilities, which can ultimately lead to unacceptable cybersecurity risks.

Another drawback of module H based on ISO 9001 stems from the fact that the CRA is not a pure product regulation but also includes internal processes of the manufacturer including vulnerability handling and development and operation of remote data processing solutions (RDPS), which are not placed on the market and generally don't fit all the requirements set out in a full QMS.

Although quality management structures are common in many sectors, their personnel and processes are not specialized for cybersecurity and might not include the necessary expertise and resources to effectively manage cybersecurity risks. Consequently, the existing quality management structures have to be adapted and enhanced to meet the specific requirements of the CRA. This also applies to NBs as QMS auditors are generally not automatically qualified to evaluate cybersecurity risks and controls.

As such, a QMS based module H is not sufficient to meet the requirements of the CRA and would require adaptations and enhancements to include rapid response to new threats, cybersecurity-specific processes and upskilling of the personnel involved in the operation and assessment of the quality management system.

C.2 Module H based on ISO/IEC 27001

An ISMS based on ISO/IEC 27001 is also built upon the PDCA cycle, but it is specifically designed for information security management and includes a comprehensive set of controls and processes to ensure conformity with the essential cybersecurity requirements of the CRA. The quality goal for an ISMS is to ensure the confidentiality, integrity and availability of information and functionality by reducing cybersecurity risks to an acceptable level which coincides with the first essential cybersecurity requirement of Annex I Part I CRA. This quality goal can be applied to the organisation itself as well as any product designed, developed and produced by the organisation.

In addition, an ISMS based on ISO/IEC 27001 is intended to handle emerging cybersecurity threats and vulnerabilities as it includes a risk management process that allows organisations to identify, assess and treat cybersecurity risks on an ongoing basis. This means that manufacturers are able to respond quickly to new threats and vulnerabilities.

Furthermore, an ISMS based on ISO/IEC 27001 is specialised for cybersecurity within an organisation and includes the necessary controls and processes to implement an appropriate level of cybersecurity including RDPS and handling of technical vulnerabilities. This means that manufacturers can leverage existing ISMS structures and expertise to meet the requirements of the CRA, which can be a significant advantage compared to a QMS based module H.

The existing cybersecurity expertise also applies to NBs as ISMS auditors are generally qualified to evaluate cybersecurity of an organisation. This enables the reuse of the existing certification body infrastructure without the need for significant additional investment in assessment of module H.

Nevertheless, an ISO/IEC 27001 based ISMS has one major drawback, as it is not directly suited to meet all quality system requirements needed for module H in the context of product development and production as an ISMS is primarily intended to assess and mitigate cybersecurity risks to the organisation and not to strictly uphold quality goals for a product. This aspect needs to be addressed through additional requirements.

In addition, controls of ISO/IEC 27001 only have to be applied based on the risk assessment. This also applies to quality system and CRA relevant controls of the organisation like secure development lifecycle, security testing in development and acceptance, change management and handling of technical vulnerabilities. As some of these controls are required to implement module H the freedom of choice given by the risk-based approach of ISO/IEC 27001 has to be restricted and based on the product risks in order to ensure conformity of the PwDE with Annex I CRA.

As such, an ISMS based module H is generally well suited to meet cybersecurity requirements but is not a quality system required for Module H. Consequently, adaptations and enhancements to include the specific requirements of the CRA as well as Module H are necessary.

C.3 Concept TR-03183-H

A QMS based on ISO 9001 as well as an ISMS based on ISO/IEC 27001 have desirable properties for the implementation of module H, but neither fulfils everything required for module H.

As such, the concept behind TR-03183-H is to combine the strengths of both standards by using an ISMS based on ISO/IEC 27001 as the foundation for module H and then enhancing it with quality system aspects to meet the specific requirements of module H in the context of product design, development and production.

This is possible as management system standards can be combined into an integrated management system (IMS) that allows organisations to leverage the strengths of multiple standards while minimizing the duplication of efforts and resources. The TR-03183-H is an approach to combine ISMS, QMS as well as hEN with presumption of conformity in one bundle which can be certified as a whole by a NB for management systems and the capabilities laid out in ISO/IEC 27006.

C.3.1 Scope of the ISMS

TR-03183-H is based on an ISMS according to ISO/IEC 27001, scoped to the parts of the organisation relevant for ensuring conformity of the PwDE with the essential cybersecurity requirements set out in Part I of Annex I and conformity of the vulnerability handling processes put in place by the manufacturer with the requirements set out in Part II of Annex I as set out in Annex VIII 3.2 CRA.

As such, the scope of the ISMS encompasses the design, development and production processes for Annex I Part I as well as the vulnerability handling processes for Annex I Part II. This entails the processes related to the parts of the PwDE placed on the market as well as the processes related to the RDPS, which are not placed on the market but are subject to the requirements of the CRA.

C.3.2 Risk Assessment

To ensure that the essential cybersecurity requirements in CRA Annex I are fulfilled, some restrictions and enhancements have to be made to ISO/IEC 27001, which are described in detail in TR-03183-H.

A central aspect of tailoring ISO/IEC 27001 to meet the needs of the CRA is the restriction of the cybersecurity risk handling process as this is generally rather open-ended in ISO/IEC 27001, which allows organisations to choose from a wide range of risk handling options [10].

The CRA requires the manufacturer to handle cybersecurity risks of a PwDE based on the intended purpose and reasonably foreseeable use, as well as the conditions of use, of the PwDE. As such, TR-03183-H requires the manufacturer to assess and adequately treat risks which might affect users, bystanders or other potentially affected third parties.

The manufacturer is not allowed to accept these risks without appropriate treatment. The risk assessment has to be performed without taking into account risks which only affect the manufacturer and might be opposed to the interests of the users, such as financial or reputational risks, as well as concepts such as risk hunger or the risk of missing out on market opportunities.

With this approach, cybersecurity risks of the PwDE are subject to the ISMS structure and automatically elevated to the same importance as organisational risks subject to management accountability, policies and procedures. This is in accordance with the general idea of the CE mark and Module H, making the manufacturer's organisation liable for cybersecurity risks of its PwDE.

C.3.3 Risk Treatment

Following ISO/IEC 27001, an organisation can freely choose appropriate controls to treat the assessed risks. The TR-03183-H concept includes a set of mandatory controls which have to be implemented by the manufacturer to ensure conformity with the essential cybersecurity requirements of the CRA.

These mandatory controls include a secure development lifecycle (SDLC) for the design, development and production of the PwDE, ensuring that the essential cybersecurity requirements of Annex I Part I are met by the PwDE as well as corresponding RDPS. The development lifecycle already contains quality system relevant requirements for planning and approving changes based on the risk

assessment as well as verifying the implementation of changes.

NOTE | Besides the SDLC additional controls for change management and managing information security in the ICT supply chain might be required as the configuration of RDPS and third-party components have an impact on the cybersecurity of a PwDE.

To fulfil the requirements of Annex I Part II CRA, the manufacturer also has to implement a technical vulnerability handling process, which includes monitoring as well as handling vulnerabilities in the products with digital elements.

C.3.4 Leveraging Presumption of Conformity

The SDLC as well as the technical vulnerability handling process are directly referencing the respective requirements of Annex I. The TR-03183-H does not include detailed instructions for the implementation of these requirements as this falls within the scope of ongoing European standardisation and alternative definitions might adversely affect market fragmentation.

As described in Annex VIII Part IV 3.3, a NB shall presume conformity with those requirements in respect of the elements of the quality system that comply with the corresponding specifications of the national standard that implements the relevant harmonised standard or technical specification.

This aspect is also used and enforced by the TR-03183-H. Manufacturers implementing Module H are required to apply applicable hEN with presumption of conformity if available. Deviating from a hEN is only allowed if the manufacturer can duly justify the deviation based on its risk assessment and can demonstrate that the alternative solution provides an equivalent level of cybersecurity.

Generally, the TR-03183-H relies heavily on the use of hEN with presumption of conformity for the evaluation, acceptance and mitigation of product-type-specific cybersecurity risks.

C.3.5 Adding quality system aspects to the ISMS

Based on the aforementioned enhancements, the described approach already includes the central aspects of a quality system for cybersecurity, i.e. a PDCA-cycle, assessment, mitigation and monitoring of cybersecurity risks, regular audits, management responsibility as well as planning, approval and verification of changes to the processes as well as to the product.

Nevertheless, there are some additional quality system aspects which are not directly related to cybersecurity but are still required for module H in the context of product design, development and production, which are not automatically included in an ISMS based on ISO/IEC 27001. These are primarily related to documentation and record keeping. Both have been added based on the requirements for technical documentation (Annex VII CRA) as well as the requirements for quality system documentation (Annex VIII Part IV CRA).

C.4 Conclusion

The concept behind TR-03183-H is to set up a comprehensive and effective approach for manufacturers to demonstrate conformity with the essential cybersecurity requirements of the CRA using an ISMS based on ISO/IEC 27001 as the foundation for module H.

This approach is new but necessary as existing quality management systems are neither fit nor sufficient to handle the complete scope of the CRA. This will allow manufacturers to leverage existing ISMS structures and expertise to meet the requirements of the CRA, which can be a significant advantage compared to a QMS based module H.

The approach described in this concept can be combined with other regulations and industry standards based on ISMS, e.g. for NIS2 conformity.

D Overview of relevant quality system aspects (informative)

Table 4: Aspects Quality System

Quality system aspect	Reference in TR-03183-H / ISO/IEC 27001	Reference in ISO 9001
Understanding the organisation, need of interested parties and scope of the ISMS	ISO/IEC 27001 Section 4 refined by CRA 4.2 & CRA 4.3 defining the users and other potentially affected third-parties as interested parties as well as scoping the ISMS to the relevant processes and services for the cybersecurity of the PwDE	ISO 9001 Section 4
Leadership responsibility and support for quality goals	ISO/IEC 27001 Section 5 refined by CRA 5.2 including conformity and appropriate cybersecurity as part of the leadership responsibilities and policies	ISO 9001 Section 5
Planning of Cybersecurity Controls and Processes	ISO/IEC 27001 Section 6 refined by CRA 6.1.2 and CRA 6.1.3 for CRA specific risk assessment and treatment. Extended by ISO 9001 6.3 adding requirements for changes to the quality system	ISO 9001 Section 6
Support of Users of the PwDE	ISO/IEC 27001 Section 7 refined by CRA 7.4 and CRA 7.5.1 to include communication with the user as well as appropriate documentation for third-party users and operation	ISO 9001 Section 7
Operation of the quality system processes	ISO/IEC 27001 Section 8 refined by CRA 8.1 to implement verification of cybersecurity risk treatment during operation. Extended by requirements of ISO 9001 8.3 - 8.7 for the design, development and production process to ensure quality including traceability, verification, control of externally provided resources, production, release and control of non-conforming outputs	ISO 9001 Section 8
Monitoring, Audits and Management Reviews	ISO/IEC 27001 Section 9. No refinement necessary as already includes every relevant aspect	ISO 9001 Section 9
Continual Improvement Processes and handling of non-conformities	ISO/IEC 27001 Section 10. No refinement necessary as already includes every relevant aspect. Handling of non-conformities on PwDE level also included in CRA 8.1.5	ISO 9001 Section 10

E Application of TR-03183-1 (informative)

The TR-03183-1 is applied using this rationale:

1. TR-03183-1 provides a set of requirements for manufacturers and products that can be used as a basis for the risk assessment and risk treatment required in 6.1.2 and 6.1.3. Applicable risk acceptance and evaluation criteria based on the intended purpose and foreseeable use of the PwDE are set out in 5.14 of TR-03183-1.
2. The controls defined in Chapter 7 of TR-03183-1 are derived for the essential cybersecurity requirements listed in Annex A.1 and A.2. The application of the controls is performed by filtering the provided control set according to the risk to generate a baseline for the PwDE and an applicability statement of essential cybersecurity requirements set out in section 6.1.3 requirement d-1.
3. Chapter 8 of TR-03183-1 refines the requirements of Annex II CRA for user information and can be used to generate appropriate user documentation as set out in section 7.5.
4. The TR-03183-1 RH_RT.1.3 establishes requirements for verification of implemented controls in the product design and development process that can be applied to fulfil the requirements of section 8.1.

F References

- [1] REGULATION (EU) 2024/2847 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act). Available: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32024R2847>
- [2] ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection – Information security management systems – Requirements, Standard, International Organization for Standardization, Geneva, CH
- [3] ISO 9001:2015 Quality management systems – Requirements, Standard, International Organization for Standardization, Geneva, CH
- [4] ISO/IEC 27000:2018, Information technology – Security techniques – Information security management systems – Overview and vocabulary, Standard, International Organization for Standardization, Geneva, CH
- [5] ISO/IEC 27002:2022, Information security, cybersecurity and privacy protection – Information security controls , Standard, International Organization for Standardization, Geneva, CH
- [6] TR-03183-1: Cyber Resilience Requirements for Manufacturers and Products, BSI, Germany, 2026. Available: <https://www.bsi.bund.de/dok/TR-03183>
- [7] OSCAL - Open Security Controls Assessment Language. Available: <https://oscal.io/>
- [8] Decision No 768/2008/EC of the European Parliament and of the Council of 9 July 2008 on a common framework for the marketing of products, and repealing Council Decision 93/465/EEC (Text with EEA relevance). Available: <https://eur-lex.europa.eu/legal-content/EN/ALL/?uri=celex:32008D0768>
- [9] ISO/IEC 17021-1:2015 Conformity assessment – Requirements for bodies providing audit and certification of management systems Part 1: Requirements, Standard, International Organization for Standardization, Geneva, CH
- [10] ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection – Guidance on managing information security risks, Standard, International Organization for Standardization, Geneva, CH